M. A. Hempkemeyer, Rev. Bras. Crim. 2026
Edição Especial dos Anais do XXVIII Congresso Nacional de Criminalística

2026
ISSN 2237-9223

REVISTA BRASILEIRA DE CRIMINALÍSTICA

Edição Especial dos Anais do

Análise Forense do Mecanismo de Bloqueio de Aplicativos (App Lock) em Dispositivos Xiaomi: Identificação de Artefatos e Inferência de Credenciais

M. A. Hempkemeyer[a,*]

[a]*Seção de Computação Forense, Polícia Científica do Paraná, Curitiba (PR), Brasil*
[*]*Endereço de e-mail para correspondência: michael.andre@policiacientifica.pr.gov.br*

Palavras-chave: Perícia computacional; dispositivos móveis; Xiaomi; App Lock; análise forense.

1. INTRODUÇÃO

A análise forense de dispositivos móveis tem sido impactada pela adoção de mecanismos adicionais de segurança implementados por fabricantes, os quais, embora não impeçam necessariamente a extração de dados por meio de ferramentas forenses especializadas, podem restringir a interação manual com o dispositivo, dificultando a execução de procedimentos complementares.

Ferramentas forenses consolidadas permitem a obtenção abrangente de dados em nível de sistema de arquivos. Entretanto, em determinados cenários, podem se mostrar insuficientes para viabilizar o acesso a conteúdos protegidos por mecanismos proprietários implementados ao nível da interface do usuário.

Dentre tais mecanismos, destaca-se a funcionalidade de bloqueio de aplicativos (App Lock) presente em dispositivos Xiaomi (MIUI/HyperOS), a qual permite restringir o acesso a aplicações específicas mediante autenticação independente da senha de desbloqueio do dispositivo.

Esse recurso pode inviabilizar atividades periciais relevantes, tais como o acesso manual a aplicativos, a verificação de configurações do sistema e a execução de procedimentos complementares.

Em aplicações como o Signal [1], cuja arquitetura prioriza a proteção dos dados, a limitação torna-se ainda mais relevante, uma vez que a análise pode depender de interação direta com o aplicativo.

Diante da ausência de mecanismos, em ferramentas forenses amplamente utilizadas no contexto pericial, capazes de identificar ou inferir a credencial associada ao bloqueio de aplicativos, o presente trabalho tem como objetivo analisar o funcionamento desse mecanismo em dispositivos Xiaomi, identificar os artefatos relacionados e propor abordagem para inferência da credencial configurada.

2. CENÁRIOS DE APLICAÇÃO

A presente pesquisa foi motivada por cenários práticos observados em contexto pericial, nos quais a funcionalidade de bloqueio de aplicativos em dispositivos Xiaomi impôs limitações relevantes à análise.

O primeiro cenário envolve a análise de aplicações de comunicação com foco em privacidade, como o Signal, cuja arquitetura dificulta a interpretação dos dados mesmo após a extração completa do sistema de arquivos. Nesses casos, a obtenção de informações relevantes pode depender da interação direta com o aplicativo em execução no dispositivo, o que se torna inviável quando há bloqueio adicional por App Lock, como, por exemplo, na realização de extração de conversas por meio de mecanismos de backup [3], quando as ferramentas tradicionais não possuem suporte para decodificação dos dados extraídos.

O segundo cenário refere-se à necessidade de execução de procedimentos técnicos diretamente no dispositivo, tais como a habilitação do modo desenvolvedor e da depuração USB, com o objetivo de viabilizar

coletas complementares de dados ou metadados. Em determinadas configurações, o acesso às configurações do sistema pode estar protegido pelo mecanismo de bloqueio de aplicativos, inviabilizando a execução desses procedimentos.

Em ambos os cenários, a presença do bloqueio de aplicativos atua como barreira adicional à análise forense, mesmo quando a extração de dados foi realizada com sucesso, evidenciando a necessidade de compreensão técnica e eventual superação desse mecanismo.

3. METODOLOGIA

O estudo foi conduzido por meio de abordagem empírica aliada à engenharia reversa, com validação em ambiente controlado, visando garantir a reprodutibilidade dos resultados.

Inicialmente, foi realizada a preparação do ambiente de teste, com dispositivos Xiaomi descritos na tabela abaixo, configurados com a funcionalidade de bloqueio de aplicativos ativa [2], utilizando diferentes tipos de credenciais, incluindo padrão geométrico, numérico e senha alfanumérica.

Tabela 1 - Dispositivos utilizados nos testes

Dispositivos Xiaomi do Ambiente de Teste		
Modelo Comercial	Modelo Técnico	Versão Sistema Operacional
Redmi 12	23053RN02A	13
Redmi Note 9S	M2003J6A1G	10
Redmi note 9t	M2007J22G	10

Observa-se que, para o padrão geométrico, é possível utilizar todos os pontos de uma grade 3×3, com exigência mínima de 4 pontos. Para a senha numérica, foi identificado que o sistema limita a entrada a exatamente 4 dígitos nos testes realizados. Já para a senha alfanumérica, observou-se a possibilidade de utilização de 4 a 11 caracteres.

Com o modo de depuração ativado, procedeu-se à interação controlada com o dispositivo por meio de shell ADB em ambiente Windows, permitindo observar o comportamento do sistema operacional ao acessar aplicações protegidas.

Por meio do comando "*adb shell dumpsys window | grep -E "mCurrentFocus|mFocusedApp"* foi possível identificar o serviço responsável pela implementação do bloqueio, vinculado ao componente nativo de segurança "*com.miui.securitycenter/com.miui.applicationlock.ConfirmAccessControl*". Considerando que a remoção ou alteração de componentes de segurança do sistema pode acarretar impactos irreversíveis na evidência digital, optou-se por abordagem não invasiva, baseada exclusivamente na análise de artefatos presentes no sistema de arquivos.

A partir da análise do sistema de arquivos completo extraído por ferramenta forense especializada (Cellebrite Premium – Inseyets UFED Pro), foram identificados os arquivos access_control.key e access_control_password_type.key localizados no diretório /data/system.

A análise desses artefatos indicou:

- associação com o mecanismo de bloqueio de aplicativos;
- armazenamento do tipo de credencial configurada;
- presença de conteúdo compatível com mecanismos de derivação baseados em funções hash;

O arquivo access_control_password_type.key apresentou indicação direta do tipo de credencial utilizada sendo pattern, numeric e mixed para geométrica, numérica e alfanumérica, respectivamente.

Já o arquivo access_control.key, analisado com auxílio do software HxD, apresentou tamanhos diferentes, sendo observado um tamanho para credenciais geométricas e outro, distinto, para credenciais numéricas e alfanuméricas, conforme imagens abaixo.

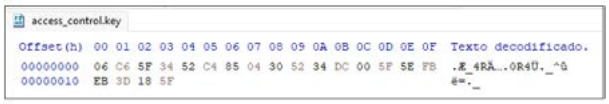


Figura 1 - Conteúdo em hexadecimal do arquivo access_control.key obtido através do HxD. de uma senha geométrica

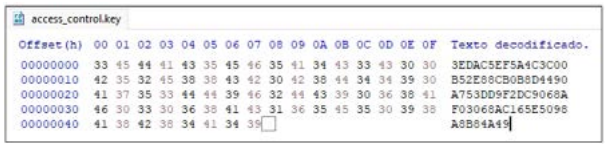


Figura 2 - Conteúdo em hexadecimal do arquivo access_control.key obtido através do HxD. de uma senha numérica

Em relação ao tipo geométrico (pattern) foi observado que o tamanho em bytes correspondia ao tamanho de saída de um hash SHA-1. Com base nessa hipótese, foi desenvolvido script em linguagem Python para geração de combinações de credenciais e cálculo de seus respectivos valores de hash, utilizando abordagem de força bruta controlada. Após testes iniciais, foi observado que o valor submetido à função hash não correspondia a uma representação textual da senha, mas sim a uma sequência ordenada de índices que representam os pontos selecionados na grade 3×3 do sistema, convertida em formato binário (bytes) antes da aplicação da função SHA-1.

A inferência da credencial foi implementada por meio de busca em profundidade (DFS), com geração de combinações válidas conforme as regras estrutu-

rais do padrão, incluindo a não repetição de pontos e a obrigatoriedade de passagem por pontos intermediários.

Ademais, observou-se que, para credenciais do tipo padrão geométrico, a mesma senha resultava no mesmo valor de hash SHA-1 em diferentes equipamentos, indicando a ausência de elementos adicionais no processo de geração do valor armazenado.

Por outro lado, para credenciais do tipo numérica e alfanumérica, verificou-se que, embora o tamanho do valor armazenado no arquivo access_control.key fosse idêntico entre si, a mesma senha resultava em valores distintos quando aplicada em diferentes dispositivos. Esse comportamento indicou a presença de parâmetros adicionais no processo de derivação, possivelmente associados ao usuário ou ao próprio equipamento, motivando análise aprofundada do mecanismo interno de geração desses valores.

4. RESULTADOS E DISCUSSÃO

Os resultados obtidos demonstraram que o mecanismo de armazenamento de credenciais varia conforme o tipo de senha configurada, apresentando diferenças significativas entre padrões geométricos e credenciais textuais (numéricas e alfanuméricas).

Enquanto o padrão geométrico utiliza um modelo direto baseado em função hash, credenciais textuais empregam um processo de derivação mais complexo, envolvendo parâmetros adicionais específicos do usuário.

4.1. Credencial do tipo padrão geométrico (Pattern)

Inicialmente, foram consideradas as regras de formação de padrões válidos do sistema Android, incluindo a não repetição de pontos e a obrigatoriedade de passagem por pontos intermediários previamente utilizados, o que reduz significativamente o espaço de busca.

Os testes iniciais indicaram ausência de correspondência para credenciais do tipo padrão geométrico quando utilizada a modelagem convencional baseada na numeração de 1 a 9.

Esse resultado levou à formulação de hipótese alternativa quanto à forma de indexação dos pontos do padrão geométrico.

A adoção de modelo baseado em indexação de 0 a 8 resultou na identificação de correspondência entre o valor gerado e o valor armazenado no arquivo access_control.key.

A validação prática da credencial obtida confirmou a eficácia da abordagem, permitindo o desbloqueio do mecanismo de App Lock.

Os resultados indicam que o mecanismo analisado utiliza função hash SHA-1 aplicada diretamente à sequência binária correspondente ao padrão geométrico, sem evidência de mecanismos adicionais de proteção, como uso de *salt* ou funções de derivação de chave. Além disso, em todos os equipamentos testados foi observado que a mesma senha resultava no mesmo valor de hash SHA-1.

4.2. Credencial do tipo Numérico (PIN)

Diferentemente do observado para o padrão geométrico, o comportamento das credenciais numéricas não se mostrou determinístico. Durante os testes, verificou-se que uma mesma senha resultava em valores distintos no arquivo access_control.key quando aplicada em diferentes dispositivos, o que indicou, desde o início, a presença de algum parâmetro adicional no processo de geração desse valor.

A análise do fluxo interno do sistema confirmou essa hipótese. O valor armazenado não corresponde a um hash direto da senha informada, nem a uma simples transformação textual. Em vez disso, a derivação final da credencial é realizada por um serviço interno do MIUI, e não pela própria interface do App Lock. Esse serviço reutiliza uma rotina legada herdada do Android para produzir o valor que será efetivamente persistido pelo sistema.

Nesse contexto, foi possível identificar que o sistema incorpora um valor de *salt* associado ao usuário, armazenado na chave lockscreen.password_salt do banco locksettings.db. Esse valor, originalmente um inteiro longo, é convertido para sua representação hexadecimal e utilizado em conjunto com a senha informada. A credencial, após convertida para bytes, é concatenada com essa representação do *salt*, formando a entrada do processo de derivação.

Sobre esse valor concatenado são então aplicadas duas funções hash distintas, SHA-1 e MD5, cujos resultados são concatenados e posteriormente codificados em hexadecimal, originando o conteúdo final armazenado no arquivo access_control.key.

Esse modelo explica diretamente o tamanho observado do artefato. O SHA-1 gera 20 bytes (40 caracteres hexadecimais) e o MD5 gera 16 bytes (32 caracteres hexadecimais), resultando em um total de 72 caracteres hexadecimais — exatamente o valor identificado nos testes.

A validação foi realizada a partir da própria extração analisada. O arquivo access_control_password_type.key indicava o tipo numeric, enquanto o conteúdo de access_control.key correspondia ao valor

derivado conforme o modelo descrito, utilizando o *salt* obtido do banco locksettings.db.

Na prática, verificou-se que tanto os modos numeric quanto mixed utilizam o mesmo mecanismo de derivação legado do Android, herdado do modelo de armazenamento de credenciais associado ao arquivo password.key, diferindo apenas quanto à forma de entrada da senha. Essa característica permite a aplicação de técnicas conhecidas de análise, desde que disponíveis os parâmetros necessários, especialmente o valor de *salt*.

4.3. Credencial do tipo alfanumérica (password)

Para credenciais alfanuméricas, identificadas pelo tipo mixed, verificou-se comportamento equivalente ao observado para credenciais numéricas. Durante os testes, constatou-se que uma mesma senha resultava em valores distintos no arquivo access_control.key quando aplicada em diferentes dispositivos, indicando a utilização do mesmo mecanismo de derivação dependente de parâmetros adicionais, como o valor de *salt*.

A análise do fluxo interno demonstrou que essas credenciais seguem o mesmo processo de derivação descrito na seção anterior, incluindo a utilização do valor lockscreen.password_salt, sua conversão para formato hexadecimal e a aplicação combinada das funções SHA-1 e MD5.

Assim, não há distinção no mecanismo de armazenamento entre credenciais numéricas e alfanuméricas, sendo a diferença restrita à natureza da entrada fornecida pelo usuário. Enquanto o tipo numeric limita a entrada a dígitos, o tipo mixed permite cadeias alfanuméricas com maior complexidade, sem alteração no processo de derivação do valor armazenado.

4.4. Abordagens de inferência e técnicas de cracking

A partir dos mecanismos identificados para cada tipo de credencial, foram adotadas abordagens distintas para inferência das senhas configuradas, em função das diferenças estruturais observadas no processo de armazenamento.

Para credenciais do tipo padrão geométrico, a inferência foi realizada por meio de script desenvolvido em linguagem Python, baseado em geração de combinações válidas conforme as regras do padrão Android. Considerando que o valor armazenado corresponde à aplicação direta da função SHA-1 sobre uma sequência binária representando os pontos selecionados, tornou-se necessária a modelagem específica dessa estrutura, não sendo aplicáveis ferramentas tradicionais de cracking baseadas em entrada textual.

Por outro lado, para credenciais dos tipos numérica e alfanumérica, a abordagem adotada baseou-se na utilização da ferramenta Hashcat, em conjunto com técnicas conhecidas de cracking de credenciais do Android em seu modelo legado. Nesse caso, a equivalência entre o mecanismo identificado e o utilizado no armazenamento de credenciais do sistema permitiu a aplicação de métodos já consolidados, desde que previamente obtidos os parâmetros necessários, em especial o valor de *salt* associado ao usuário.

Dessa forma, observa-se que a viabilidade de utilização de ferramentas tradicionais de cracking está diretamente relacionada ao modelo de armazenamento adotado para cada tipo de credencial, exigindo, no caso do padrão geométrico, abordagem customizada, e, para credenciais textuais, adaptação de técnicas já conhecidas no contexto de análise forense de dispositivos Android.

4.5. Considerações gerais de segurança

Os resultados obtidos evidenciam que o mecanismo de bloqueio de aplicativos em dispositivos Xiaomi adota abordagens distintas conforme o tipo de credencial, variando entre um modelo determinístico para padrões geométricos e um modelo derivado, baseado em *salt*, para credenciais textuais.

Do ponto de vista pericial, essa distinção impacta diretamente a viabilidade de inferência das credenciais, sendo mais imediata no caso de padrões geométricos e condicionada à obtenção de parâmetros adicionais, como o valor de *salt*, no caso de credenciais numéricas e alfanuméricas.

Observa-se, ainda, que o mecanismo empregado para credenciais textuais é baseado em modelo legado do Android, com aplicação das funções SHA-1 e MD5 sobre o valor derivado, cujos resultados são posteriormente concatenados. Embora a utilização de *salt* represente uma melhoria em relação a abordagens determinísticas, o emprego de funções consideradas obsoletas para fins criptográficos pode ser entendido como uma limitação do ponto de vista de segurança.

Adicionalmente, a reutilização desse modelo indica ausência de adoção de mecanismos mais robustos de proteção de credenciais disponíveis em versões mais recentes do sistema.

5. LIMITAÇÕES E TRABALHOS FUTUROS

O presente estudo apresenta limitações relacionadas à quantidade de dispositivos e versões do sistema

operacional analisadas, não sendo possível generalizar os resultados para todas as versões do MIUI/HyperOS.

Adicionalmente, não foi possível verificar eventuais alterações no mecanismo de derivação das credenciais em versões mais recentes do sistema, o que pode impactar a aplicabilidade da metodologia proposta, especialmente considerando a possível substituição de mecanismos legados por abordagens mais modernas.

Outra limitação relevante refere-se à dependência de acesso ao sistema de arquivos completo, necessária para obtenção de artefatos críticos, como o valor de *salt*, sem o qual não é possível reproduzir o processo de derivação de credenciais textuais.

Como trabalhos futuros, sugerem-se:

- análise comparativa entre diferentes versões do sistema Xiaomi;
- avaliação de outros fabricantes com mecanismos similares;
- desenvolvimento de ferramenta automatizada para identificação, extração e análise desses artefatos;

6. CONCLUSÕES

O presente trabalho demonstrou que o mecanismo de bloqueio de aplicativos em dispositivos Xiaomi pode ser analisado por meio da identificação e interpretação de artefatos específicos no sistema de arquivos.

Os resultados evidenciaram que o processo de armazenamento de credenciais da função nativa de App Lock varia conforme o tipo de senha utilizada. Enquanto o padrão geométrico é armazenado por meio de função hash SHA-1 aplicada diretamente à sua representação estrutural, credenciais numéricas e alfanuméricas utilizam mecanismo de derivação baseado no modelo legado do Android, com aplicação das funções SHA-1 e MD5, cujos resultados são concatenados, com uso de *salt* por usuário.

A metodologia proposta mostrou-se eficaz para compreensão desses mecanismos e para reprodução do processo de derivação, permitindo, em cenários específicos, a inferência da credencial configurada pelo usuário, especialmente no caso de padrões geométricos ou quando disponíveis os parâmetros necessários para credenciais textuais.

Os achados reforçam a relevância da análise empírica e da engenharia reversa de artefatos proprietários no contexto da perícia computacional, bem como evidenciam a persistência de mecanismos legados em sistemas atuais, os quais podem representar limitações do ponto de vista de segurança.

Ressalta-se, contudo, que a aplicação da metodologia proposta depende da obtenção prévia de extração completa do sistema de arquivos do dispositivo, condição essencial para acesso aos artefatos analisados. Dessa forma, a técnica descrita não constitui método autônomo de superação do bloqueio, estando condicionada ao uso de ferramentas forenses capazes de viabilizar tal nível de extração.

REFERÊNCIAS BIBLIOGRÁFICAS

[1] Sginal. Disponível em: https://signal.org/pt_BR/. Acesso em: 29/03/2026.

[2] Application Lock. Disponível em: https://www.mi.com/global/support/article/KA-03725/. Acesso em: 29/03/2026.

[3] Signalbackup-tools. Disponível em: https://github.com/bepaald/signalbackup-tools. Acesso em: 30/03/2026.

[4] Breaking Samsung Android Passwords/PIN. Disponível em: https://www.web3us.com/cyber-security/breaking-samsung-android-passwordspin. Acesso em: 02/04/2026.

[5] Breaking Samsung Android Passwords/PIN. Disponível em: https://hashcat.net/forum/thread-2202.html. Acesso em: 02/04/2026.